

Business logic vulnerabilities

Lab: Authentication bypass via flawed state machine

Cilj zadatka: zaobići mehanizam autentikacije, pristupiti administratorskom panelu i obrisati korisnika carlos. Ranjivost: aplikacija poseduje logičku grešku u dizajnu toka prijave. Pretpostavlja se da će korisnik uvek pratiti strogo definisan redosled koraka (Login -> Role Selection -> Home). Međutim, aplikacija ne proverava da li je korisnik zaista prošao kroz korak odabira uloge pre nego što mu dodeli podrazumevane (u ovom slučaju administratorske) privilegije.

Postupak rešavanja:

1. Ulogovati se na aplikaciju sa odgovarajućim kredencijalima
2. Primetiti da se nakon uspešnog unosa lozinke ne učitava direktno početna strana nego međukorak odabira uloge

The screenshot shows the Web Security Academy lab interface. At the top left is the 'Web Security Academy' logo. To its right is the lab title 'Authentication bypass via flawed state machine'. Further right are two tabs: 'LAB' (active) and 'Not solved'. Below the title is an orange button 'Back to lab home' and a link 'Back to lab description >>'. A horizontal line separates the header from the main content. In the top right of the main content area are links 'Home' and 'My account'. The main content area has a light blue background and contains the text 'Please select a role'. Below this is a dropdown menu with 'User' selected and a green 'Select' button.

3. Analizom putanja identifikovati postojanje administratorske putanje /admin
4. Primetiti da pokušaj direktnog pristupa na /admin u fazi odabira uloge nije moguć
5. Izlogovati se, vratiti se na login stranicu, uključiti Burp intercept i ponovo se ulogovati
6. Proslediti POST /login zahtev klikom na Forward

Dashboard Target **Proxy** Intruder Repeater Collaborator Sequencer Decoder Comparer Logger Organizer Extensions Discover

Intercept HTTP history WebSockets history Match and replace Proxy settings

Intercept on Forward Drop Request to https://0a80001504c34549835bc30c006700f5.web-security-academy.net:443 [34.246.129.62] Open browser

Time	Type	Direction	Method	URL	Status code	Length
05:31:57 9 Jun...	WS	→ To server		https://0a80001504c34549835bc30c006700f5.web-security-academy.net/academy/LabHeader		
05:32:13 9 Jun...	HTTP	→ Request	POST	https://0a80001504c34549835bc30c006700f5.web-security-academy.net/login		4

Request
Pretty Raw Hex
1 POST /login HTTP/2
2 Host: 0a80001504c34549835bc30c006700f5.web-security-academy.net
3 Cookie: session=Fv0fAq1G07yqv0kASX5gv17cUVRtsCpLh
4 Content-Length: 60
5 Cache-Control: max-age=0
6 Sec-Ch-Ua: "Jfot-A.Brand",v="14", "Chromium",v="146"
7 Sec-Ch-Ua-Mobile: 0
8 Sec-Ch-Ua-Platform: "Windows"
9 Accept-Language: en-US,en;q=0.9
10 Origin: https://0a80001504c34549835bc30c006700f5.web-security-academy.net
11 Content-Type: application/x-www-form-urlencoded
12 Upgrade-Insecure-Requests: 1

Inspector
Request attributes 2
Request query parameters 0
Request body parameters 3
Request cookies 1
Request headers 23

Event log (5) All issues Memory: 564.6MB of 7.84GB Disabled

7. Sledeći zahtev GET /role-selector uništiti klikom na Drop

Dashboard Target **Proxy** Intruder Repeater Collaborator Sequencer

Decoder Comparer Logger Organizer Extensions Discover

Intercept **HTTP history** WebSockets history Match and replace Proxy settings

Intercept on Forward Drop Open browser

Type	Direction	Method	URL
WS	→ To serv...		https://0a80001504c34549835bc30c006700f5.web-security-academy.net/academyLabHeader
HT...	→ Request	GET	https://0a80001504c34549835bc30c006700f5.web-security-academy.net/role-selector

Request

Pretty Raw Hex

```

1 GET /role-selector HTTP/2
2 Host:
0a80001504c34549835bc30c006700f5.web-security-
academy.net
3 Cookie: session=
ARBDYRNq6JRSUwmET7Eaw6B0hLyMMHKQ
4 Cache-Control: max-age=0
5 Accept-Language: en-US,en;q=0.9
6 Upgrade-Insecure-Requests: 1
7 User-Agent: Mozilla/5.0 (Windows NT 10.0;

```

0 highlights

Inspector

Request attributes 2

Request query parameters 0

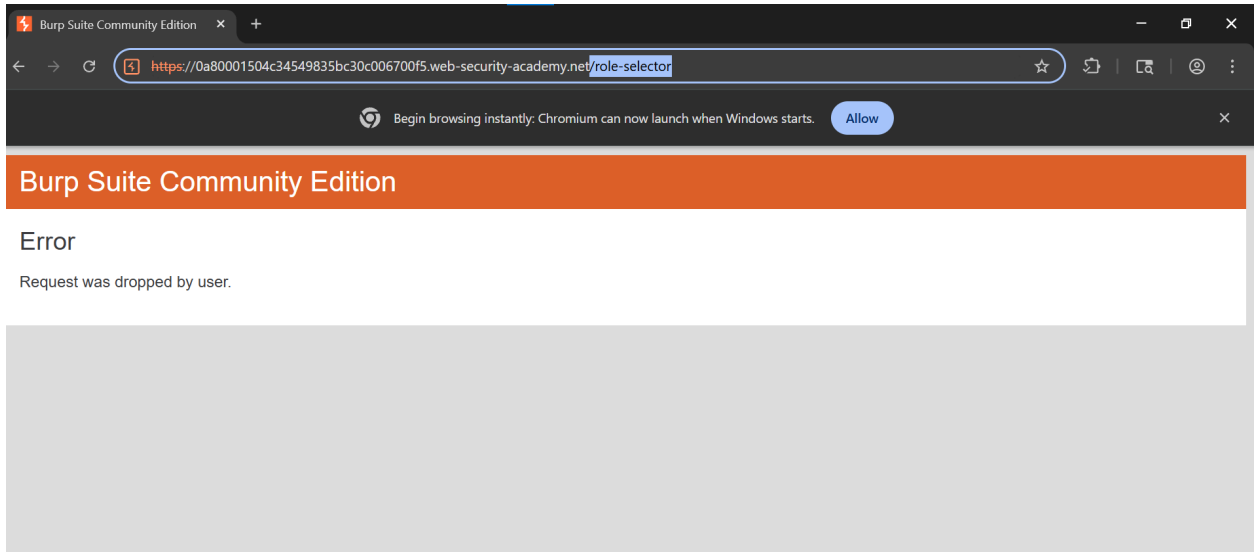
Request body parameters 0

Request cookies 1

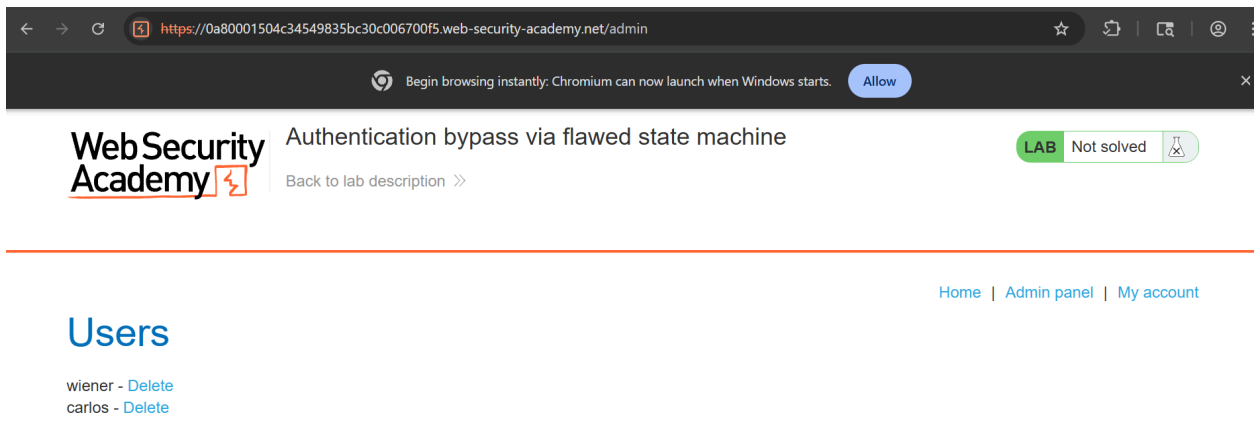
Request headers 20

Event log (5) All issues Memory: 564.6MB of 7.84GB Disabled

8. Obrisati u URL-u sve nakon glavnog domena i dodati /admin



9. Nakon učitavanja putanje, otvara se administratorski panel



10. Brisanjem korisnika carlos rešava se zadatak



Congratulations, you solved the lab!

Share your skills!



[Continue learning >>](#)

[Home](#) | [Admin panel](#) | [My account](#)

User deleted successfully!

Users

wiener - [Delete](#)
